

# HIPAA Compliance & EMR Integration Guide

A Practical Roadmap for InnovateHealth.ai

What to do before touching PHI, penetration testing, Athenahealth integration, and EMR comparison

Version 1.0 | March 2026

# Table of Contents

- 1. Your HIPAA Readiness Checklist: Before Touching PHI ..... 3
- 2. Technical Safeguards You Must Implement ..... 5
- 3. Penetration Testing: Should You Do It? ..... 8
- 4. Business Associate Agreements (BAAs) Status ..... 10
- 5. Athenahealth Integration: Step-by-Step ..... 11
- 6. EMR Integration Comparison: Epic, Cerner, and Others ..... 15
- 7. Compliance Automation Tools ..... 18
- 8. Your 90-Day Action Plan ..... 19
- 9. Sources ..... 21

# 1. Your HIPAA Readiness Checklist

## Before Touching PHI

Before InnovateHealth.ai processes any Protected Health Information (PHI), you need these foundations in place. This is not optional — the HIPAA Security Rule (45 CFR Part 164) requires documented safeguards before any ePHI access.<sup>1</sup>

Where you stand today: You already have BAAs with Retell AI (voice) and Azure (cloud). That covers two of your key vendors. Below is everything else you need to complete.

## Pre-PHI Compliance Checklist

| Category                | Requirement                                                                                                                                           | Status / Action                                                    |
|-------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------|
| Risk Assessment         | Complete a formal HIPAA Security Risk Analysis — document all systems that will store, process, or transmit ePHI (Azure, Retell, your SaaS dashboard) | Must do first. Use NIST SP 800-30 framework.                       |
| Risk Management Plan    | Document identified risks, mitigation actions, responsible owners, and timelines                                                                      | Create after risk assessment. Required by 45 CFR 164.308(a)(1).    |
| Policies and Procedures | Write HIPAA policies covering: data access, incident response, workforce training, password management, device management, sanctions                  | Draft and get team sign-off. Templates available from Vanta/Drata. |
| BAAs with All Vendors   | Every vendor that touches ePHI needs a signed BAA — Retell (done), Azure (done), any analytics, logging, or email tools                               | Audit all vendors. Any missing BAA = HIPAA violation risk.         |
| Workforce Training      | All team members handling PHI must complete HIPAA training and sign acknowledgment                                                                    | Required annually. Document completion.                            |
| Incident Response Plan  | Documented procedure for detecting, containing, investigating, and reporting breaches                                                                 | Must include 60-day notification timeline to HHS.                  |
| Data Map                | Map exactly where PHI flows: entry point (voice call) through processing (Retell/Azure) through storage (database) through display (dashboard)        | Critical for your risk assessment.                                 |

1. HIPAA Journal, "HIPAA Compliance Checklist - 2026 Update," <https://www.hipaajournal.com/hipaa-compliance-checklist/>

## 2. Technical Safeguards You Must Implement

The HIPAA Security Rule (45 CFR 164.312) defines specific technical safeguards for any system that handles ePHI. These are the concrete engineering requirements your development team needs to build into your SaaS platform.<sup>2</sup>

### Access Controls (Required)

| Control                                 | What to Implement                                                                                  | Your System                                                                  |
|-----------------------------------------|----------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------|
| Unique User IDs (Required)              | Every person and service account accessing ePHI must have a unique identifier. No shared accounts. | Dashboard users, API service accounts, admin accounts — all need unique IDs. |
| Emergency Access Procedure (Required)   | Document a break-glass process to access ePHI during emergencies when normal auth is down.         | Write a procedure. Test it during DR drills.                                 |
| Automatic Logoff (Addressable)          | Sessions timeout after inactivity. Implement session expiry on your dashboard.                     | 15-minute timeout recommended. Re-auth for sensitive actions.                |
| Encryption and Decryption (Addressable) | ePHI must be unreadable to unauthorized persons at rest and in transit.                            | See encryption section below. 'Addressable' does NOT mean optional.          |

"Addressable" does not mean optional. Under HIPAA, if encryption is reasonable and appropriate for your environment (it is — you are a cloud SaaS), you MUST implement it. If you choose not to, you must document your reasoning AND implement an equivalent alternative. In practice, OCR expects encryption for cloud SaaS companies.

### Encryption Requirements

Encryption is arguably the most critical technical safeguard. Here is exactly what to implement:<sup>3</sup>

| Scope           | Requirement                                                      | Implementation for InnovateHealth                                                                                 |
|-----------------|------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------|
| Data at Rest    | AES-256 encryption for all databases and storage containing ePHI | Azure provides transparent data encryption (TDE) by default. Enable it on all storage accounts and SQL databases. |
| Data in Transit | TLS 1.2 or higher for all network communication                  | Enforce TLS 1.2+ on your dashboard, APIs, and any data exchange with Retell/Azure. Disable TLS 1.0/1.1.           |

| Scope            | Requirement                                        | Implementation for InnovateHealth                                                           |
|------------------|----------------------------------------------------|---------------------------------------------------------------------------------------------|
| Key Management   | Use FIPS 140-2 (or 140-3) validated key management | Azure Key Vault meets this. Store all encryption keys there, never in code or config files. |
| Backups          | Encrypted backups with separate key storage        | Azure Backup encrypts by default. Verify this is enabled.                                   |
| End-User Devices | Encrypt any device that may access ePHI            | Enforce full-disk encryption (BitLocker/FileVault) on team laptops via policy.              |

## Audit Controls (Required)

You must log all activity involving ePHI and review those logs regularly.<sup>4</sup> This means:

- Log every access to ePHI — who, when, what record, from what IP/device
- Log login/logout events, failed authentication attempts, and permission changes
- Store logs in a tamper-resistant system (Azure Monitor / Log Analytics)
- Set up alerts for suspicious patterns (multiple failed logins, unusual access times, bulk data exports)
- Review audit logs at least monthly — document the review
- Retain logs for a minimum of 6 years (HIPAA retention requirement)

## Authentication (Required)

Implement person or entity authentication to verify that anyone requesting access to ePHI is who they claim to be:

- Multi-Factor Authentication (MFA) — Required for all admin and ePHI access. Use Azure AD MFA or similar.
- Strong Password Policy — Minimum 12 characters, complexity requirements, no password reuse.
- OAuth 2.0 for API Access — Use token-based authentication for all API integrations (Retell, Athenahealth).
- Service Account Management — Rotate API keys and secrets regularly. Store in Azure Key Vault.

## Integrity Controls (Addressable)

Ensure ePHI is not improperly altered or destroyed. Implement checksums, version control on records, and database integrity verification.

## Transmission Security (Required)

Guard against unauthorized access to ePHI during transmission. This overlaps with encryption in transit but also covers network security:

- TLS 1.2+ everywhere (APIs, dashboard, webhooks, Retell voice data)
- VPN or private endpoints for internal Azure communication
- Network segmentation — isolate ePHI-handling components from public-facing services
- Firewall rules restricting access to ePHI databases to only necessary services

2. HHS, "Technical Safeguards - HIPAA Security Series,"

<https://www.hhs.gov/sites/default/files/ocr/privacy/hipaa/administrative/securityrule/techsafeguards.pdf>

3. HIPAA Journal, "HIPAA Encryption Requirements - 2026 Update," <https://www.hipaajournal.com/hipaa-encryption-requirements/>

4. Censinet, "HIPAA Access Control Requirements Explained,"

<https://censinet.com/perspectives/hipaa-access-control-requirements-explained>

### 3. Penetration Testing

#### Should You Do It? Yes — Here's When and How

HIPAA does not explicitly require penetration testing, but the Security Rule requires regular technical evaluation of your security controls (45 CFR 164.308(a)(8)). In practice, penetration testing is the industry standard for meeting this requirement, and any enterprise healthcare customer or health system will ask for it.<sup>5</sup>

Our recommendation: Do a penetration test BEFORE you go live with PHI, not after. It is much cheaper to fix vulnerabilities before production than after a breach. For your stage, a SaaS-focused pentest in the \$4,000-\$8,000 range will satisfy requirements.

#### When to Schedule

- Before first PHI exposure — Get your initial pentest done before going live
- After major changes — New features, infrastructure changes, or new integrations
- Annually at minimum — Standard expectation for HIPAA and enterprise sales
- 60-90 days before audits — Allow time for remediation before any compliance audit

#### Cost Breakdown

| Type                                  | Cost Range (2026)    | Notes                                                               |
|---------------------------------------|----------------------|---------------------------------------------------------------------|
| SaaS Application Pentest (your stage) | \$4,000 — \$8,000    | Covers web app, APIs, cloud config. This is what you need first.    |
| HIPAA-Aligned Pentest (full scope)    | \$12,000 — \$30,000+ | Includes data flow testing, segmentation, compliance documentation. |
| Mobile App Pentest (if applicable)    | \$6,000 — \$25,000   | Per platform (iOS/Android) plus backend APIs.                       |
| Bundled Compliance + Pentest          | Varies               | Some firms bundle pentest with SOC 2 or HIPAA readiness work.       |

#### What Gets Tested

- Your SaaS dashboard — authentication, authorization, session management, input validation
- APIs — Retell integration endpoints, any Athenahealth-facing APIs, internal APIs
- Azure cloud configuration — storage permissions, network security groups, key management
- Data encryption verification — at rest and in transit
- Social engineering (optional) — phishing simulation against your team

Tip: Start with a focused SaaS pentest (\$4K-\$8K). As you scale and onboard more clinics, move to a full HIPAA-aligned pentest. Many firms like SecureLeap, Cobalt, and HackerOne specialize in startup-friendly healthcare pentests.

5. SecureLeap, "Pentest Pricing: How Much to Budget for Penetration Testing in 2026,"  
<https://www.secureleap.tech/blog/penetration-testing-cost-startup-pricing>



## 4. Business Associate Agreements (BAAs)

### Your Current Status and What's Missing

Every vendor, subcontractor, or service that can access, store, or transmit ePHI on your behalf must have a signed BAA with you. Without it, you are in violation of HIPAA, and any breach involving that vendor exposes you to full liability.

| Vendor              | Purpose                   | Status | Notes                                                                |
|---------------------|---------------------------|--------|----------------------------------------------------------------------|
| Retell AI           | Voice AI platform         | Signed | You already have this in place.                                      |
| Microsoft Azure     | Cloud infrastructure      | Signed | Azure's standard BAA covers their HIPAA-eligible services.           |
| Athenahealth        | EMR integration           | Needed | Required before any PHI exchange. Part of their integration process. |
| Email Provider      | If emails contain any PHI | Check  | Gmail does NOT sign BAAs. Consider Microsoft 365 (BAA available).    |
| Analytics / Logging | If logs contain ePHI      | Check  | Ensure Azure Monitor is covered under Azure BAA.                     |
| Any Other SaaS Tool | If it touches ePHI        | Audit  | Review every tool in your stack.                                     |

Critical check: Audit every tool your team uses. Slack, Notion, Google Docs, email — if any PHI could flow through them (even accidentally), you need a BAA. If the vendor does not offer a BAA, you cannot use that tool for PHI.

## 5. Athenahealth Integration

### Step-by-Step Guide for InnovateHealth.ai

Dr. Nikhil's clinic (Blessings Medical Clinic) uses Athenahealth as their EMR. This is your first and most important integration. The good news: Athenahealth is one of the more developer-friendly EMRs with free certified APIs and zero marketplace fees.<sup>6</sup>

Key facts about Athenahealth integration:

- 800+ API endpoints, publicly documented
- FHIR R4 standard (HTI-1 compliant as of May 2025)
- OAuth 2.0 authentication with SMART-on-FHIR support
- Marketplace has zero fees — no setup, no revenue share
- Site-specific URLs per practice (e.g., /fhir/r4/{practice\_id}/)

### Integration Timeline

| Step                            | What Happens                                                                                                        | Timeline                        |
|---------------------------------|---------------------------------------------------------------------------------------------------------------------|---------------------------------|
| 1. Developer Account            | Register at the Athenahealth Developer Portal. Get sandbox access.                                                  | 2-3 business days               |
| 2. Scope Your Integration       | Define exactly what data you need (appointments, patient demographics, clinical notes). Build a FHIR Data Contract. | 1 week (internal)               |
| 3. App Registration             | Register your app for OAuth. Define scopes, redirect URIs.                                                          | 3-7 business days for approval  |
| 4. Sandbox Development          | Build and test against sandbox with mock data. Implement OAuth 2.0, FHIR R4 endpoints, data mapping.                | 4-8 weeks                       |
| 5. BAA and Contracts            | Sign BAA with Athenahealth. Complete authorization and consent form.                                                | 1-3 weeks (can overlap with #4) |
| 6. Production Credentials       | Get production API keys. Blocked until BAA is complete.                                                             | 1-2 weeks after BAA             |
| 7. Pilot with Blessings Medical | Test with Dr. Nikhil's real practice. Validate data flows.                                                          | 2-4 weeks                       |

Total estimated timeline: 6-12 weeks from developer account to live integration with Blessings Medical Clinic. This is significantly faster than Epic or most other EMRs.

## Cost

Athenahealth's certified FHIR APIs are free — no setup fees, no per-call charges, no revenue share through the Marketplace.<sup>7</sup> Your costs are primarily developer time:

| Item                          | Cost             | Notes                                                                                         |
|-------------------------------|------------------|-----------------------------------------------------------------------------------------------|
| API Access / Marketplace Fees | \$0              | Certified APIs are free. Marketplace listing is optional and free.                            |
| Developer Time (4-8 weeks)    | Your team's time | Primary cost. 1-2 engineers working on the integration.                                       |
| Non-Certified API Fees        | Possible fees    | If you need legacy/proprietary endpoints, Athena may charge. Avoid if possible — use FHIR R4. |
| BAA / Legal                   | Minimal          | Standard process, no fee from Athenahealth side.                                              |

## Technical Requirements

- FHIR R4 Standard — Athena uses FHIR R4 (required since HTI-1, May 2025). Key resources: Patient, Encounter, Observation, Condition, Appointment, DocumentReference.
- OAuth 2.0 / SMART-on-FHIR — Use 2-legged (system-to-system) or 3-legged (user-authorized) OAuth flows. PKCE required by 2026.
- Site-Specific URLs — Each practice has a unique base URL: `api.platform.athenahealth.com/fhir/r4/{practice_id}/`. Your code must handle this dynamically.
- Rate Limits — Production: 100 requests/second, 500,000/day. Sandbox: 15 req/s, 50,000/day. Design with caching and backoff.
- Webhooks — Event subscriptions available but ID-only (you must fetch the full resource). 2-second response SLA, no retries. Queue webhooks immediately.
- Data Mapping — FHIR data can be messy (e.g., Condition often returned as plain text strings). Build a normalization/adaptor layer.

## What Athenahealth Requires from You

| Requirement              | Details                                                                                             |
|--------------------------|-----------------------------------------------------------------------------------------------------|
| BAA Signed               | Must be signed before production API access. Standard process.                                      |
| HIPAA Compliance         | They vet partners for security and HIPAA compliance before Marketplace listing.                     |
| OAuth 2.0 Implementation | Proper auth flow — no storing user credentials, use tokens.                                         |
| Practice Authorization   | The practice (Dr. Nikhil's clinic) must authorize your app to access their data via a consent form. |

| Requirement      | Details                                                                              |
|------------------|--------------------------------------------------------------------------------------|
| HTI-1 Compliance | Your FHIR implementation must meet HTI-1 requirements (FHIR R4, USCDI data classes). |

Tip for Dr. Nikhil's Clinic: Since Blessings Medical Clinic already uses Athenahealth, Dr. Nikhil can authorize your integration from within his athenaOne dashboard. The clinic signs a consent form allowing your app access. No additional cost to the clinic.

6. Topflight Apps, "Athena EMR/EHR Integration: 7-Step Guide for 2026," <https://topflightapps.com/ideas/athena-ehr-emr-integration/>

7. Athenahealth, "Marketplace FAQ,"

<https://www.athenahealth.com/~media/athenaweb/files/marketplace/pdfs/marketplacefaq040416.pdf>

## 6. EMR Integration Comparison

### Athenahealth vs. Epic vs. Others

As InnovateHealth.ai scales beyond Blessings Medical Clinic, you will need to integrate with other EMR systems. Here is a practical comparison of the major EMRs for third-party integration difficulty, cost, and timeline.<sup>8</sup>

| EMR System             | Timeline    | Cost                             | Difficulty | Key Notes                                                                                                                               |
|------------------------|-------------|----------------------------------|------------|-----------------------------------------------------------------------------------------------------------------------------------------|
| Athenahealth           | 6-12 weeks  | \$0 (API fees), Dev time only    | Easy-Med.  | FHIR R4, 800+ endpoints, free certified APIs, zero Marketplace fees. Best for small/mid practices.                                      |
| Epic                   | 6-12 months | \$50K-\$200K+ total project cost | Hard       | Requires Vendor Services membership (\$1.7K-\$1.9K/yr), SOC 2 or HITRUST cert (\$30K-\$100K+), per-site approvals. Dominates hospitals. |
| Oracle Health (Cerner) | 3-6 months  | Moderate (less than Epic)        | Moderate   | Ignite APIs, CommonWell Health Alliance, more flexible than Epic. Good for large health systems.                                        |
| eClinicalWorks         | 4-8 weeks   | Low-Moderate                     | Easy-Med.  | Carequality integration, 1,000+ hospitals/40,000 clinics connected. Cloud-native, affordable.                                           |
| Veradigm (Allscripts)  | 4-8 weeks   | Low-Moderate                     | Easy       | Multiple integration paths (traditional, APIs, pre-built apps). Good for ambulatory care.                                               |

### Epic: Why It's Different (and Harder)

Epic dominates the hospital market (over 35% of US hospitals). If you ever sell to a hospital system, you will likely need Epic integration. But it is significantly more complex and expensive than Athenahealth:<sup>9</sup>

| Phase                        | Timeline           | Cost             | Details                                                                                     |
|------------------------------|--------------------|------------------|---------------------------------------------------------------------------------------------|
| App Registration             | Days to 4 weeks    | \$500-\$1,900/yr | Register in Epic Connection Hub or Showroom. Get developer sandbox.                         |
| Sandbox Development          | 2-6 months         | \$50K-\$150K+    | Largest investment. 2-3 engineers needed. FHIR R4 (plus legacy DSTU2/STU3 for older sites). |
| Validation and Certification | 1-4 months         | \$20K-\$80K      | Security testing, SOC 2/HITRUST certification, BAA negotiations.                            |
| Production Go-Live           | 2-4 weeks per site | \$5K-\$15K/site  | Every Epic customer site requires individual approval and configuration.                    |

Epic's per-site approval is the real bottleneck. Even after you are certified with Epic, every single hospital/clinic that uses Epic must individually approve your integration. This means your sales cycle includes an IT approval process at every site.

## Integration Strategy Recommendation

Given your stage, here is the recommended order of EMR integrations:

- Now (Q1-Q2 2026): Athenahealth — Start here. Low cost, fast timeline, Dr. Nikhil's clinic is your pilot. Perfect for proving your product works.
- When Selling to Larger Practices (Q3-Q4 2026): eClinicalWorks or Veradigm — Both are affordable and common among mid-size practices.
- When Targeting Hospital Systems (2027+): Epic — Only invest the \$50K-\$200K when you have enterprise customers who specifically need it.
- Consider Middleware: Platforms like Redox (\$11K-\$270K/year) or Health Gorilla can abstract away EMR differences. Worth evaluating once you need 3+ EMR integrations.

8. Dash Technologies, "Epic EHR Integration vs Other Systems: Comparison Guide,"  
<https://dashtechinc.com/blog/epic-ehr-integration-vs-other-systems-comparison-guide-2025/>

9. Topflight Apps, "How to Integrate a Health App with Epic EHR/EMR in 2026,"  
<https://topflightapps.com/ideas/how-integrate-health-app-with-epic-ehr-emr/>

## 7. Compliance Automation Tools

### Do You Need One?

Compliance automation platforms like Vanta, Drata, Secureframe, and Sprinto can dramatically reduce the manual effort of HIPAA compliance. They automate evidence collection, policy management, workforce training, and audit preparation.<sup>10</sup>

Our recommendation for your stage: Consider a tool like Sprinto (\$5K-\$10K/year) or Drata (\$10K-\$18K/year). They are worth it when you start handling PHI regularly and need to demonstrate compliance to clinic customers. Not critical for day one, but plan for it.

| Tool        | Startup Pricing          | Key Features                                                                                     | Notes for You                                                     |
|-------------|--------------------------|--------------------------------------------------------------------------------------------------|-------------------------------------------------------------------|
| Vanta       | \$10K-\$12K/yr (startup) | Largest market share. 375+ integrations. Best auditor network. Supports HIPAA, SOC 2, ISO 27001. | Great all-rounder, slightly pricey for early-stage.               |
| Drata       | \$10K-\$18K/yr (startup) | Clean UI, strong automation, real-time evidence collection. Good HIPAA support.                  | Strong alternative to Vanta. Slightly more flexible on contracts. |
| Secureframe | \$7.5K-\$20K/yr          | Includes advisory/consulting component. Guided workflows.                                        | Good if you want more hand-holding through compliance.            |
| Sprinto     | \$5K-\$10K/yr            | Most affordable. Good for budget-conscious startups.                                             | Fewer integrations, more manual work. Good starting point.        |

### What These Tools Help With

- Automated evidence collection (pull compliance data from Azure, GitHub, etc.)
- Pre-built HIPAA policy templates (saves weeks of writing)
- Employee HIPAA training modules with tracking
- Continuous monitoring of your cloud security posture
- Audit-ready dashboard for when customers ask about compliance
- Vendor management (tracking BAAs, vendor risk assessments)

<sup>10</sup>. Cavanex, "Vanta vs Drata vs Secureframe vs Sprinto (2026 Comparison)," <https://cavanex.com/blog/soc-2-compliance-platforms-compared-2026>

## 8. Your 90-Day Action Plan

Here is a concrete, week-by-week plan to get InnovateHealth.ai HIPAA-ready and integrated with Athenahealth:

### Phase 1: Foundation (Weeks 1–3)

| When   | Action                                                                                                                                              |
|--------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
| Week 1 | Complete HIPAA Security Risk Assessment. Map all PHI data flows (voice call entry through Retell, processing on Azure, storage, dashboard display). |
| Week 1 | Start writing HIPAA policies and procedures. Use templates from a compliance platform or a healthcare attorney.                                     |
| Week 2 | Implement technical safeguards: encryption at rest (Azure TDE), TLS 1.2+ everywhere, MFA on all admin accounts, audit logging in Azure Monitor.     |
| Week 2 | Audit all vendors for BAA coverage. Sign BAAs with any vendor missing one.                                                                          |
| Week 3 | Complete employee HIPAA training. Document everything.                                                                                              |
| Week 3 | Write and test your Incident Response Plan.                                                                                                         |

### Phase 2: Pentest + Athena Setup (Weeks 4–6)

| When   | Action                                                                                                                                           |
|--------|--------------------------------------------------------------------------------------------------------------------------------------------------|
| Week 4 | Engage a penetration testing firm. Schedule your first SaaS pentest (\$4K-\$8K).                                                                 |
| Week 4 | Register for Athenahealth Developer Portal. Get sandbox access.                                                                                  |
| Week 5 | Define your Athena integration scope: what data do you need? Appointments? Patient demographics? Encounter notes? Build your FHIR Data Contract. |
| Week 5 | Register your app with Athenahealth for OAuth. Request production BAA.                                                                           |
| Week 6 | Begin Athena sandbox development. Implement OAuth 2.0, test FHIR R4 endpoints.                                                                   |
| Week 6 | Receive and remediate pentest results. Fix any critical/high findings.                                                                           |

### Phase 3: Build + Go Live (Weeks 7–12)



| When        | Action                                                                                                                                                          |
|-------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Weeks 7-10  | Complete Athena integration development. Build data mapping/normalization layer. Implement webhook handling with queue. Handle rate limits and error scenarios. |
| Week 8      | Get BAA signed with Athenahealth. Obtain production API credentials.                                                                                            |
| Week 9      | Get Dr. Nikhil to authorize your app in his athenaOne dashboard (consent form).                                                                                 |
| Weeks 10-12 | Pilot test with Blessings Medical Clinic. Validate real data flows. Fix edge cases.                                                                             |
| Week 12     | Go live. Monitor closely. Review audit logs daily in the first week.                                                                                            |

After the 90 days: You should have a HIPAA-compliant system, a clean pentest report, and a working Athenahealth integration at Blessings Medical Clinic. From there, you can onboard additional clinics and evaluate other EMR integrations as needed.

## 9. Sources

1. HIPAA Journal, "HIPAA Compliance Checklist - 2026 Update", <https://www.hipaajournal.com/hipaa-compliance-checklist/>
2. HHS, "Technical Safeguards - HIPAA Security Series", <https://www.hhs.gov/sites/default/files/ocr/privacy/hipaa/administrative/securityrule/techsafeguards.pdf>
3. HIPAA Journal, "HIPAA Encryption Requirements - 2026 Update", <https://www.hipaajournal.com/hipaa-encryption-requirements/>
4. Censinet, "HIPAA Access Control Requirements Explained", <https://censinet.com/perspectives/hipaa-access-control-requirements-explained>
5. SecureLeap, "Pentest Pricing: How Much to Budget in 2026", <https://www.secureleap.tech/blog/penetration-testing-cost-startup-pricing>
6. Topflight Apps, "Athena EMR/EHR Integration: 7-Step Guide for 2026", <https://topflightapps.com/ideas/athena-ehr-emr-integration/>
7. Athenahealth, "Marketplace FAQ", <https://www.athenahealth.com/~media/athenaweb/files/marketplace/pdfs/marketplacefaq040416.pdf>
8. Dash Technologies, "Epic EHR Integration vs Other Systems", <https://dashtechinc.com/blog/epic-ehr-integration-vs-other-systems-comparison-guide-2025/>
9. Topflight Apps, "How to Integrate a Health App with Epic EHR/EMR in 2026", <https://topflightapps.com/ideas/how-integrate-health-app-with-epic-ehr-emr/>
10. Cavanex, "Vanta vs Drata vs Secureframe vs Sprinto (2026 Comparison)", <https://cavanex.com/blog/soc-2-compliance-platforms-compared-2026>
11. GDPR Local, "HIPAA Compliance Checklist: Important Requirements for 2026", <https://gdprlocal.com/hipaa-compliance-checklist-2026/>
12. Secureframe, "The Ultimate HIPAA Compliance Checklist for 2026", <https://secureframe.com/blog/hipaa-compliance-checklist>
13. Accountable, "HIPAA Encryption Rule Explained", <https://www.accountablehq.com/post/hipaa-encryption-rule-explained-what-the-security-rule-actually-requires>
14. Athenahealth Developer Portal, <https://www.athenahealth.com/developer-portal>
15. PayPro Global, "How to Achieve HIPAA Compliance for SaaS", <https://payproglobal.com/how-to/achieve-hipaa-compliance-for-saas/>